

Lista de Exercícios para Avaliação

Unidade 1 — Segurança de redes locais e de longa distância · Subunidade 1.1 — Introdução a testes de invasão

Nome do(a) aluno(a): Gustavo Anibele	Data: 10 /08/2026
Professor: José Carlos Neto	Valor: 3,0 pontos (Listas/Prática — Av1)

Instruções

Responda a todas as questões de forma individual, com justificativa quando solicitado. Cálculos devem ser demonstrados — a resposta final sem o desenvolvimento não pontua integralmente. Consultas ao material de aula são permitidas; consulta a colegas, não.

Parte 1 — Conceitos de rede

1. **[Conceitual]** Explique a função de cada uma das quatro camadas do modelo TCP/IP, citando um protocolo de exemplo para cada uma.

Resposta:

Camada de aplicação: É a camada onde as aplicações compartilham os dados. Um exemplo é o protocolo http.

Camada de transporte: É a camada responsável pela segmentação dos dados. Um exemplo de protocolo é o tcp.

Camada de internet: É a camada responsável por endereçar e comunicar hosts e redes. Um exemplo de protocolo é o ip.

Camada de rede: É a camada de transporte de bits e troca de informação entre dispositivos. Um exemplo é o wi-fi.

2. **[Conceitual]** Diferencie TCP e UDP, citando ao menos duas características de cada um e um exemplo de aplicação que utiliza cada protocolo.

Resposta:

TCP: Transmission Control Protocol. Nesse protocolo, existe a confiabilidade de que o pacote foi recebido, pois existe a confirmação de entrega, integridade e o controle de fluxo. Um exemplo pode ser o uso de http para web.

UDP: User Datagram Protocol. Ele é mais rápido, mas não garante a entrega ou a ordem dos pacotes. Um exemplo pode ser o uso de streaming de vídeos.

3. **[Conceitual]** O que é NAT e por que ele continua sendo necessário na maioria das redes atuais, mesmo com a existência do IPv6?

Resposta: NAT é uma técnica utilizada para permitir que múltiplos dispositivos em uma rede privada compartilhem um único endereço IP público. Serve para economizar ips ipv4.

Parte 2 — Endereçamento e cálculo de sub-redes

4. **[Cálculo]** Para o bloco 172.16.0.0/22, calcule:

(a) a máscara de sub-rede em notação decimal;

Resposta: 255.255.252.0

(b) a quantidade de hosts utilizáveis;

Resposta: 1022

(c) o endereço de broadcast.

Resposta: 172.16.3.255

5. **[Cálculo]** Divida o bloco 200.10.5.0/24 em 8 sub-redes de tamanho igual. Indique a nova máscara (CIDR) e liste os 8 blocos resultantes.

Resposta: máscara /27.

Endereços: 200.10.5.0, 200.10.5.32, 200.10.5.64, 200.10.5. 96, 200.10.5.128, 200.10.5.160,

200.10.5.192, 200.10.5.224.

6. **[Cálculo]** Os hosts 10.20.30.10/28 e 10.20.30.30/28 estão na mesma sub-rede? Demonstre o cálculo que justifica sua resposta.

Resposta: Não. Pois como a /28 tem 16 endereços, ‘.10’ e ‘.30’ não podem estar na mesma rede. A primeira está em (0-15) e a segunda em (16-31).

Parte 3 — Serviços, ataques e testes de invasão

7. **[Aplicação]** Complete a tabela abaixo com o protocolo de transporte (TCP ou UDP) e o serviço correspondente a cada porta.

Porta	Protocolo (TCP/UDP)	Serviço
21	TCP	FTP
25	TCP	SMTP
110	TCP	POP3
143	TCP	IMAP
3306	TCP	MYSQL

8. **[Conceitual]** Diferencie os três tipos de teste de invasão — black box, grey box e white box — e indique uma situação em que cada um seria o mais indicado.

Resposta:

Black box: É quando quem simula o ataque não tem nenhuma informação interna do sistema ou equipe. Indicado para simular um ataque real.

Grey box: O atacante tem algumas informações sobre o sistema ou equipe. Indicado para simular um ataque de alguém com acesso interno ao sistema.

White box: O atacante tem acesso completo ao sistema, então foca em descobrir falhas de segurança. Indicado para análise de segurança.

9. **[Conceitual]** Segundo a Lei 12.737/2012, por que um teste de invasão realizado sem autorização formal é considerado crime, mesmo quando feito com boas intenções?

Resposta: Segundo a lei, não importa a intenção de quem faz o ataque e qualquer tipo de invasão não autorizada ou roubo de dados é crime.

10. **[Dissertativa]** Cite dois controles de rede vistos em aula (por exemplo: firewall, VLAN, MFA, segmentação) e explique como cada um reduz a superfície de ataque em uma rede corporativa.

Resposta:

Firewall: Reduz a entrada de tráfego não autorizado, filtrando e bloqueando o tráfego que não atende às regras de segurança definidas.

MFA: Impede acessos não autorizados, exigindo uma segunda forma de verificação além do login padrão, como um código enviado por SMS ou um token de segurança.

GABARITO — USO DO PROFESSOR

Referências de correção — aceitar respostas equivalentes, desde que corretamente justificadas.

1. Camadas do TCP/IP

Aplicação (HTTP, DNS, SSH, FTP) — troca de dados entre programas; Transporte (TCP, UDP) — entrega entre processos, com ou sem garantia; Internet/Rede (IP, ICMP) — endereçamento e roteamento entre redes; Acesso à rede (Ethernet, Wi-Fi) — transmissão física dos bits.

2. TCP x UDP

TCP: confiável, orientado a conexão, garante ordem e entrega (three-way handshake) — ex.: HTTP, SSH. UDP: sem conexão, mais rápido, não garante entrega/ordem — ex.: DNS, streaming, VoIP.

3. NAT

Traduz endereços privados internos em um único IP público, permitindo que vários dispositivos compartilhem um IPv4 — ainda essencial pelo esgotamento do IPv4 e pela adoção parcial/gradual do IPv6.

4. 172.16.0.0/22

(a) Máscara: 255.255.252.0. (b) Hosts utilizáveis: $2^{10} - 2 = 1022$. (c) Broadcast: 172.16.3.255.

5. 200.10.5.0/24 em 8 sub-redes

Nova máscara: /27. Blocos: 200.10.5.0/27, .32/27, .64/27, .96/27, .128/27, .160/27, .192/27, .224/27.

6. 10.20.30.10/28 e 10.20.30.30/28

Não estão na mesma sub-rede: cada bloco /28 tem 16 endereços; 10.20.30.10 pertence a 10.20.30.0/28 (0–15) e 10.20.30.30 pertence a 10.20.30.16/28 (16–31).

7. Tabela de portas

21 → TCP → FTP (controle) · 25 → TCP → SMTP (envio de e-mail) · 110 → TCP → POP3 · 143 → TCP → IMAP · 3306 → TCP → MySQL

8. Tipos de teste de invasão

Black box: nenhuma informação prévia — simula atacante externo. Grey box: informação parcial (ex.: conta comum) — simula ameaça interna limitada. White box: acesso completo — foca profundidade, não descoberta.

9. Lei 12.737/2012

A lei tipifica como crime a invasão de dispositivo informático mediante violação indevida de mecanismo de segurança — a intenção declarada não afasta o crime; só a autorização formal do responsável pelo sistema o faz.

10. Controles de rede (resposta aberta)

Aceitar qualquer combinação coerente — ex.: Firewall/ACL filtram tráfego por regra; VLAN isola segmentos e limita movimento lateral; MFA reduz o impacto de uma senha vazada; segmentação limita o alcance de um host comprometido.